

Informe Técnico de Seguridad y Arquitectura

Puyo Express

Documento de Arquitectura y Configuración

16 de julio de 2026

Introducción

Este documento técnico detalla las medidas y controles de seguridad implementados en la arquitectura de **Puyo Express**. A continuación se exponen las especificaciones, mecanismos criptográficos y configuraciones de red, junto con su respectiva ubicación en el código fuente para su revisión y auditoría.

1. Inventario de Activos y Clasificación de Datos

Descripción de la implementación:

El proyecto mantiene un inventario de activos de información donde se clasifica la criticidad de los datos (contraseñas, teléfonos, direcciones, correos) y se establecen las normativas para su persistencia segura.

Ubicación de la documentación:

`docs/security/ASSET_INVENTORY.md`

Justificación técnica:

Permite garantizar que los datos sensibles sean tratados con el nivel de protección criptográfica adecuado desde la capa de acceso a datos, reduciendo el riesgo de exposición ante una brecha de seguridad (Data Breach) y estandarizando las políticas de retención.

2. Mecanismos Criptográficos y Auditoría (Logs)

Descripción de la implementación:

- **Cifrado en reposo (AES-256-GCM):** Aplicado a nivel de columna para datos personales identificables (PII) como teléfonos y direcciones de entrega. Este cifrado simétrico autenticado garantiza confidencialidad e integridad del campo en la base de datos.
- **Firma de tokens (HMAC-SHA256):** El algoritmo HS256 se utiliza para la firma de los JSON Web Tokens (JWT), asegurando la inmutabilidad de las sesiones y la validación de identidad del cliente sin exponer estado en el servidor.

- **Derivación de claves (BCrypt):** Empleado con un factor de trabajo adecuado (costo 12) para el almacenamiento de contraseñas. Previene ataques de fuerza bruta y mitigación de tablas arcoíris mediante el uso de salteo automático (salting).
- **Auditoría de Seguridad:** Los eventos críticos de autenticación y autorización se persisten mediante un logger específico, sin registrar payloads ni credenciales.

Ubicación de la implementación:

Configuración: `backend/src/main/resources/application.yml` (parámetros `app.crypto.data-key` y `logging.level.SECURITY_AUDIT`).

Código fuente: `backend/src/main/java/com/puyoexpress/backend/security`.

3. Hardening del Host y Entorno de Ejecución

Descripción de la implementación:

El entorno del servidor host se somete a controles de endurecimiento. Esto incluye la validación de cifrado de almacenamiento a nivel de bloque (BitLocker/LUKS), validación del estado del cortafuegos (Firewall), protección antivirus en tiempo real y la desactivación de protocolos vulnerables (ej. SMBv1).

Ubicación de la implementación:

Script de validación: `scripts/audit-server-hardening.ps1`

Reporte estático: `docs/security/SERVER_HARDENING_REPORT.md`

4. Aislamiento de Red mediante Docker

Descripción de la implementación:

Los servicios se despliegan en infraestructuras de red virtualizadas (Bridge Networks). Los servicios internos (Base de datos PostgreSQL y backend Spring Boot) se aíslan en la subred `data_net` y `app_net`. No se exponen puertos al host público. Únicamente el proxy inverso (Frontend/Nginx) mapea un puerto al loopback de la máquina host (`127.0.0.1:8088`).

Ubicación de la implementación:

Directiva `networks` y `expose` en `docker-compose.yml`.

5. Ocultación de Firmas de Software (Server Tokens)

Descripción de la implementación:

Se suprime la propagación de las cabeceras HTTP que identifican las tecnologías y versiones del servidor. Esto interrumpe la fase de reconocimiento de ataques automatizados y análisis pasivo por parte de agentes maliciosos.

Ubicación de la implementación:

Nginx (Frontend proxy): `frontend/nginx.conf` mediante la directiva `server_tokens off`; y `proxy_hide_header Server`;

Tomcat (Backend): `backend/src/main/resources/application.yml` mediante `server.server-headers`.

6. Prevención de Agotamiento de Recursos (Limitación de Payload)

Descripción de la implementación:

Se establecen límites estrictos en la recepción de payloads HTTP para mitigar ataques de Denegación de Servicio (DoS) que exploten el agotamiento de memoria o ancho de banda.

Ubicación de la implementación:

Nginx (Frontend proxy): `frontend/nginx.conf` mediante `client_max_body_size 1m`;
Tomcat (Backend): `backend/src/main/resources/application.yml` definiendo el umbral en 1048576 bytes (1MB) a través de propiedades de sistema y límites multiparte.